Security Requirements Specification

Collaborative Study Material and Online Quiz Platform

Team Members:
Sanjith K S (PES1UG24CS613)
Fathima Zahra (PES1UG24CS664)
Dhanush S Shekhar (PES1UG24CS662)

Version 1.0 | 15 October 2026

1. Introduction

This document specifies the security requirements of the Collaborative Study Material and Online Quiz Platform. It follows the security requirements phase: section 2 assesses the security risks, section 3 turns the important risks into measurable (SMART) objectives, and section 4 states clear, testable security requirements that trace back to those risks and objectives. Section 5 gives the traceability matrix and section 6 the scope and assumptions.

The security requirements are part of the non-functional requirements. They extend NFR-02 (Security) and NFR-06 of the SRS and do not replace them.

2. Security Risk Assessment

2.1 Assets and Stakeholders

ID	Asset	Stakeholders	Why it has value
A-01	User credentials (passwords)	Students, Authorized users, Admin/Moderators	Access to an account means access to everything that user can do; users often reuse passwords elsewhere.
A-02	Access tokens and the token signing secret	All users, development team	A forged or stolen token is equal to stolen credentials for any user.
A-03	Personal data (name, email, bio)	Students, Authorized users	Privacy of the people using the platform.
A-04	Roles and permissions	Admin/Moderators, Authorized users	They decide who may manage official content, moderate and administer.
A-05	Channels and memberships	Students, Authorized users, Admin/Moderators	They decide who may see channel content and chat.
A-06	Study materials and links	Students, Authorized users	Contributors' work, and what other students download and trust.
A-07	Question bank and quiz content	Students, Authorized users	Quizzes are only fair if answers stay hidden and questions are not tampered with.
A-08	Quiz attempts and results	Students	Private performance data used for analytics and recommendations.
A-09	Database and source repository	Development team	They hold all of the above, and the repository is public.

2.2 Attackers

ID	Attacker	Gain sought	Capability and access
AT-1	External attacker (no account)	Account takeover, data theft, defacement, using the server for other attacks	Can reach the public web address; can use automated tools.
AT-2	Malicious registered user	Higher privileges, other users' data, unfair quiz scores, inflated reputation	Has a valid account and can send any request to the API.
AT-3	Insider with elevated role	Misuse of moderator or admin powers	Holds an Authorized user, Moderator or Admin role.
AT-4	Careless developer or tool	No gain; causes accidental leaks (for example a committed secret)	Has write access to the repository and configuration.

2.3 Threats

ID	Threat	Assets affected	Existing weakness	Attackers
T-01	Brute-force or credential-stuffing attack on login	A-01	No limit on login attempts; weak passwords allowed	AT-1
T-02	Token forgery, theft or reuse	A-02	Tokens that never expire or use a guessable secret	AT-1, AT-2
T-03	Unauthenticated access to API endpoints	A-03 to A-08	An endpoint added without an authentication check	AT-1
T-04	Privilege escalation by choosing or changing one's own role	A-04	Role accepted from the client	AT-2
T-05	Broken access control: reading or changing data that is not the user's own	A-05 to A-08	Missing membership or ownership check; predictable identifiers	AT-2, AT-3
T-06	Injection and stored cross-site scripting	A-03, A-06, A-07, A-09	User text trusted and shown without encoding	AT-1, AT-2
T-07	Malicious file or link upload	A-06, A-09	File name trusted instead of content; no size limit	AT-2
T-08	Quiz answer leakage and score tampering	A-07, A-08	Answers or scores handled on the client	AT-2
T-09	Exposure of personal data in responses	A-01, A-03	Whole database records returned by the API	AT-1, AT-2
T-10	Leaked secrets or intercepted traffic	A-01, A-02, A-09	Secrets in source control; traffic not encrypted	AT-1, AT-4
T-11	Rating and report manipulation	A-06, A-07	Unlimited ratings and reports per user	AT-2

ID	Threat	Assets affected	Existing weakness	Attackers
T-12	Vulnerable third-party dependencies	A-09	Outdated packages with public exploits	AT-1

2.4 Risk Categorization

Rating method: High = low cost of exploit, high probability and high damage. Medium = medium cost, probability and damage. Low = high cost, low probability and low damage. Where the three differ, the rating follows the closest profile.

ID	Threat	Attacker	Cost of exploit	Probability	Damage	Risk	Main mitigation
T-01	Brute force on login	AT-1	Low	High	Medium	High	Limit failed attempts, strong password storage and rules (SEC-01, SEC-02)
T-02	Token forgery or theft	AT-1, AT-2	Medium	Medium	High	Medium	Signed short-lived tokens, strong secret (SEC-03)
T-03	Unauthenticated access	AT-1	Low	Medium	High	High	Token required on every endpoint (SEC-04)
T-04	Role escalation	AT-2	Low	Medium	High	High	Roles assigned only by the server (SEC-05)
T-05	Broken access control	AT-2, AT-3	Low	High	High	High	Membership and ownership check on every request (SEC-06)
T-06	Injection and XSS	AT-1, AT-2	Medium	Medium	High	Medium	Schema validation, bound parameters, output encoding (SEC-07)
T-07	Malicious upload	AT-2	Low	High	Medium	High	Type allow-list by content, size cap, safe storage (SEC-08)
T-08	Quiz leakage or tampering	AT-2	Low	Medium	Medium	Medium	Answers hidden until submit, server-side scoring (SEC-09)
T-09	Personal data exposure	AT-1, AT-2	Medium	Medium	High	Medium	Return only permitted fields (SEC-10)
T-10	Leaked secrets or traffic	AT-1, AT-4	Medium	Medium	High	Medium	Secrets outside the repository, HTTPS (SEC-11)
T-11	Rating manipulation	AT-2	Low	Medium	Low	Low	One rating per user, no self-rating, report limit (SEC-12)
T-12	Vulnerable dependencies	AT-1	Medium	Medium	Medium	Medium	Automated dependency scan (SEC-13)

3. Security Objectives

Each High and Medium risk is converted into a SMART objective. The Low risk (T-11) is covered by a requirement without a separate objective.

ID	Objective (Specific)	Measure (Measurable)	Achievable	Relevant to	Time-bound
SO-01	Protect login against brute-force guessing.	At most 5 failed logins per account in 15 minutes; the 6th attempt is rejected with HTTP 429 in 10 of 10 test runs.	A per-account counter; no extra service needed.	T-01	End of Sprint 1 (23 Oct 2026)

ID	Objective (Specific)	Measure (Measurable)	Achievable	Relevant to	Time-bound
SO-02	Store passwords only as salted, memory-hard hashes and require a basic strength.	0 plain-text passwords in the database or logs; minimum 8 characters with letters and digits; 0 of 5 weak test passwords accepted.	Standard library functions exist for hashing.	T-01	End of Sprint 1 (23 Oct 2026)
SO-03	Require authentication on every protected endpoint.	100% of endpoints other than health, registration, login and documentation return 401 without a valid token.	One shared dependency applied to all routes.	T-03	End of Sprint 1 (23 Oct 2026)
SO-04	Keep tokens unforgeable and short-lived.	Signature secret of at least 32 bytes from the environment; lifetime of at most 30 minutes; a missing or short secret blocks login.	Standard token signing.	T-02	End of Sprint 1 (23 Oct 2026)
SO-05	Enforce role and membership checks on every protected endpoint.	0 successful unauthorized requests in a negative-test suite of at least 10 cases; 403 for insufficient role or non-member in 100% of them.	Shared permission checks reused by each module.	T-04, T-05	End of Sprint 1 for endpoints built in it; end of Sprint 2 for the rest
SO-06	Block injection and stored script attacks.	100% of request bodies validated by a schema with length limits; 0 raw SQL strings; 0 unencoded payloads in a 10-payload script/SQL test set.	Schema validation and the ORM are already part of the framework.	T-06	End of Sprint 2 (30 Oct 2026)
SO-07	Accept only safe files and links.	Allowed-type list enforced; uploads over 20 MB rejected; only http and https links accepted; 0 of 10 disallowed test files stored.	Content check using a small library.	T-07	Before upload is released, end of Sprint 2 (30 Oct 2026)
SO-08	Keep quizzes fair.	Correct answers appear in 0 responses before submission; scores are calculated on the server in 100% of attempts.	Scoring already runs on the server.	T-08	End of Sprint 2 (30 Oct 2026)
SO-09	Limit exposure of personal data.	0 API responses contain a password hash or another user’s email address.	Response schemas list allowed fields.	T-09	End of Sprint 1 (23 Oct 2026)
SO-10	Keep secrets out of the repository and encrypt traffic when deployed.	0 secrets found by a repository scan; TLS 1.2 or higher on 100% of deployed traffic.	Environment variables and a standard certificate.	T-10	Secrets: end of Sprint 1. Traffic: before any deployment.
SO-11	Detect vulnerable dependencies early.	A dependency scan runs on every pull request; 0 unresolved critical or high findings at the freeze.	A scan step in the existing automated pipeline.	T-12	Freeze (30 Oct 2026)

4. Security Requirements

Req ID	Type	Description	Priority	Acceptance Criteria	Rationale
SEC-01	Security – Authentication	User passwords shall be at least 8 characters long and contain letters and digits, and shall be stored only as salted, memory-hard hashes (for example scrypt, bcrypt or Argon2). Passwords and hashes shall never be returned in API responses or written to logs.	High	Pass: The database holds no plain-text password; a password of 7 characters, or without a digit, is rejected at registration; no API response or log line contains a password or hash. Fail: A plain-text or reversibly encrypted password is stored, a weak password is accepted, or a password or hash appears in a response or log.	A leaked database must not expose passwords, and strong storage slows offline guessing. Mitigates T-01; meets SO-02. Extends FR-01 and NFR-02.
SEC-02	Security – Authentication	The system shall allow at most 5 failed login attempts per account in 15 minutes. Further attempts shall be rejected with HTTP 429 until the 15 minutes have passed, even if the password is correct. Every failed login shall return the same message, "Invalid username or password", and shall be logged with the account and time.	High	Pass: The 6th attempt within 15 minutes is rejected with 429; a wrong username and a wrong password return the same message; each failure appears in the log. Fail: Unlimited attempts are possible, the message shows which part was wrong, or failures are not logged.	Guessing passwords is the cheapest attack on user accounts. Mitigates T-01; meets SO-01. Extends FR-01.
SEC-03	Security – Session Management	Access tokens shall be signed with a secret of at least 32 random bytes read from the environment, shall expire within 30 minutes, and shall be rejected with HTTP 401 when missing, modified or expired. A suspended account shall be refused even if it holds a valid token.	Medium	Pass: A request with no token, a modified token or an expired token returns 401; with a missing or short secret the system will not issue tokens; the token of a suspended user stops working. Fail: A protected feature works without a valid token, an expired token is accepted, or a suspended user keeps access.	A forgeable or long-lived token is equal to stolen credentials. Mitigates T-02; meets SO-04. Extends FR-01, FR-14 and NFR-02.
SEC-04	Security – Authentication (Endpoints)	Every endpoint except the health check, registration, login and the API documentation page shall require a valid token.	High	Pass: A request without a token to every other endpoint on the full endpoint list returns 401. Fail: Any other endpoint answers a request that has no valid token.	Authentication is the first control against outsiders. Mitigates T-03; meets SO-03. Extends FR-01.
SEC-05	Security – Authorization (Roles)	Roles (Student, Authorized user, Admin/Moderator) shall be assigned only by the server. A client shall not be able to choose or change its own role at registration or through a profile update, and only an Admin may grant the Authorized user or Admin/Moderator role.	High	Pass: A registration or profile request that contains a role field does not change the role; a Student who tries to create an Authorized Channel, manage official content or open the admin page is refused by the server (for example "Only authorized users/admins can create Authorized Channels", "Insufficient permissions", "Unauthorized"), including when the request is sent straight to the API. Fail: A user can choose or raise their own role, or a role-restricted action succeeds without the role.	Roles control every other permission. Mitigates T-04; meets SO-05. Extends FR-01, FR-02, FR-03 and NFR-02.

Req ID	Type	Description	Priority	Acceptance Criteria	Rationale
SEC-06	Security – Authorization (Resource Access)	Access to channels, members, materials, questions, quizzes, chat messages and quiz attempts shall be checked against the requester's membership or ownership on every request. A user who leaves or is removed from a channel shall lose access to its content immediately, and changing an identifier in a request shall not let a user reach another user's data.	High	Pass: A non-member who opens a channel directly is refused ("Join the channel to view this chat"); a removed member can no longer open the channel; changing the identifier of a quiz attempt, material or message to another user's returns 403 or 404 and changes nothing. Fail: Channel content is visible to a non-member, or one user can read or change another user's data by guessing an identifier.	Stops users from reading or changing data that is not theirs. Mitigates T-05; meets SO-05. Extends FR-02, FR-03, FR-10 and NFR-02.
SEC-07	Security – Input Handling	All request data shall be validated against a schema with type, format and length limits. Database access shall use the ORM or bound parameters only, and user-written text (material titles, reviews, questions, chat messages, bio) shall be encoded when displayed so that it cannot run as script.	Medium	Pass: An invalid email is rejected with "Enter a valid email address"; a missing required field is rejected (for example "Subject is required"); the text <script>alert(1)</script> and the fragment ' OR 1=1 -- are stored and shown as plain text and change or return no data. Fail: Injected script runs in another user's browser, or injected SQL changes or returns data.	Many users share the same data and pages, so every input is untrusted. Mitigates T-06; meets SO-06. Extends NFR-02, FR-04, FR-05 and FR-10.
SEC-08	Security – File Upload	Uploads shall be accepted only for allowed file types (PDF, DOCX, PPTX, TXT, PNG, JPG), checked by content and not only by file name, shall be at most 20 MB, and shall be stored under generated names outside the web root. Shared links shall use http or https only.	High	Pass: A disallowed file, a file over 20 MB, or an executable renamed to .pdf is rejected and not stored; a link that starts with javascript: is rejected; a stored file cannot be run by the server. Fail: A disallowed file or link is accepted, or a stored file can be executed.	Material sharing is the main route for malicious files and links. Mitigates T-07; meets SO-07. Extends FR-04 (use case UC-03).
SEC-09	Security – Quiz Integrity	Correct answers and explanations shall not be sent to the client before an attempt is submitted. Scores shall be calculated on the server only, and a score or answer key sent by a client shall be ignored.	Medium	Pass: Quiz content returned before submission contains no correct answers; a request that includes a score is ignored and the stored score is the one the server calculated. Fail: Correct answers can be read before submission, or a client-supplied score is stored.	Fair quizzes and trustworthy analytics need server-side scoring. Mitigates T-08; meets SO-08. Extends FR-06, FR-12 and NFR-06.
SEC-10	Security – Data Protection	API responses shall contain only the fields the viewer is entitled to: never a password hash, and never another user's email address. Private data such as quiz attempts and direct messages shall be readable only by its owner.	Medium	Pass: No response contains a password hash; viewing another user's profile shows no email address; another user's quiz attempt cannot be read. Fail: A response exposes a hash or another user's email, or private data can be read by someone other than its owner.	Returning less data limits the harm if another control fails. Mitigates T-09; meets SO-09. Extends FR-01, FR-11 and NFR-02.

Req ID	Type	Description	Priority	Acceptance Criteria	Rationale
SEC-11	Security – Secrets and Transport	Secrets (token signing secret, database URL, any API key) shall be supplied through environment variables or a secret manager and never committed to the repository; only an example file with placeholders shall be committed. Where the system is deployed, all traffic shall use HTTPS (TLS 1.2 or higher) and tokens shall never appear in URLs. Any LLM key shall be used only on the server.	Medium	Pass: A secret scan of the repository and its history finds no key, password or token; the example file holds placeholders only; a deployed instance refuses or redirects plain HTTP; no token appears in a URL. Fail: A secret is found in the repository, or a deployed instance accepts plain HTTP.	A secret in a public repository must be treated as leaked, and encryption protects credentials in transit. Mitigates T-10; meets SO-10. Extends NFR-02.
SEC-12	Security – Abuse Prevention	A user shall be able to rate a given material or question at most once, shall not be able to rate their own contribution, and shall be limited to 20 reports per day.	Low	Pass: A second rating by the same user updates the first instead of adding another; rating one's own material is refused; the 21st report in a day is refused. Fail: A user can rate the same item repeatedly, rate their own contribution, or file unlimited reports.	Keeps reputation and moderation signals trustworthy. Mitigates T-11. Extends FR-04, FR-05 and FR-13.
SEC-13	Security – Dependencies	Dependencies shall be scanned for known vulnerabilities by the automated pipeline on every pull request and before the freeze. Any critical or high finding shall be fixed, or accepted in writing with a reason.	Medium	Pass: The pipeline reports a dependency scan on every pull request; at the freeze no critical or high finding is open without a written acceptance. Fail: No scan runs, or an unresolved critical or high finding remains at the freeze.	Public flaws in third-party code are easy to exploit. Mitigates T-12; meets SO-11. Extends NFR-07.

5. Traceability Matrix

Each requirement is traceable to the threats it mitigates, the objective it satisfies and the SRS requirements it extends.

Requirement	Threats mitigated	Security objective	Related SRS requirement
SEC-01	T-01	SO-02	FR-01, NFR-02
SEC-02	T-01	SO-01	FR-01
SEC-03	T-02	SO-04	FR-01, FR-14, NFR-02
SEC-04	T-03	SO-03	FR-01
SEC-05	T-04	SO-05	FR-01, FR-02, FR-03, NFR-02
SEC-06	T-05	SO-05	FR-02, FR-03, FR-10, NFR-02
SEC-07	T-06	SO-06	NFR-02, FR-04, FR-05, FR-10
SEC-08	T-07	SO-07	FR-04 (use case UC-03)
SEC-09	T-08	SO-08	FR-06, FR-12, NFR-06

Requirement	Threats mitigated	Security objective	Related SRS requirement
SEC-10	T-09	SO-09	FR-01, FR-11, NFR-02
SEC-11	T-10	SO-10	NFR-02
SEC-12	T-11	Low risk, no separate objective	FR-04, FR-05, FR-13
SEC-13	T-12	SO-11	NFR-07

6. Scope and Assumptions

- Scope: the web application and its API for the two-sprint release (Sprint 1: 19–23 October 2026, Sprint 2: 26–30 October 2026).
- Not specified in this release: LLM-specific controls (prompt injection, request limits), an audit trail for admin and moderation actions, encrypted database backups and a global rate limit. They belong to features that are not part of this release (FR-07 to FR-09, FR-14 and NFR-04) and are accepted residual risk until those features are built. Failed logins are still logged under SEC-02. Requirements that mention these later features (for example account suspension and direct messages) apply once the features are built.
- The numbers (5 failed attempts in 15 minutes, 30-minute token, 8-character password, 20 MB upload, 20 reports a day) are starting values proposed by the team and may be tuned without changing the requirement.
- The 8-character minimum password matches the passwords used in the Test Plan.
- Personal data held is limited to name, email address and bio. The platform holds no payment data.
- Verification: each Pass criterion in section 4 becomes a test case, to be added to the Test Plan.